

Reachy Mini local — full project audit

Read-only review of this checkout · 31 August 2026 · 2 high, 12 medium, 7 low findings · includes recommended next work

Verdict: runnable household stack, not a merge-ready tree

The app, dashboard, and tests are in good shape for this machine: local speech-to-speech, Hermes, Home Assistant, reef, and a spoken boot diagnostic. The two issues that actually bite are the unauthenticated UI on 0.0.0.0:7860 and the 45–180s nested Hermes hop. Do not treat main as clean — local work and full-tree backups are sitting uncommitted on it.

2

High findings

12

Medium findings

7

Low findings

~450

Tests in tests/

Findings by severity (21 total)

Conversation app

54 Python modules, 15,289 lines under src/.

Entry: reachy-mini-conversation-app → main.run(). Realtime loop is HuggingFaceRealtimeHandler.

Control dashboard

11 modules, 2,381 lines. Default 127.0.0.1:8788.

Starts llama, speech-to-speech, Hermes, and the conversation app from services.json. No auth. Secrets redacted.

Tests

44 test modules, 11,626 lines — about 0.76× src by line count.

Strongest: realtime (57), bus monitor (45), console (38), boot diagnostic (24), dashboard (21).

Scope is the conversation app, control dashboard, default profile, tests, and working tree. Excludes _backups/ contents except as a hygiene finding. Not an upstream Pollen Robotics security review of reachy_mini itself.

1. Recommended next work

Highest-leverage follow-ups from this audit. All items are pending.

- PENDING** — Bind the conversation UI to 127.0.0.1 by default; document 0.0.0.0 as an explicit LAN choice.
- PENDING** — Whitelist dashboard log service ids and resolve-under-LOG_DIR.
- PENDING** — Cancel the Hermes httpx POST when the originating turn is superseded.
- PENDING** — Add _backups/ to .gitignore and move local work off main onto feat/ branches.
- PENDING** — Drop reef_status from the default profile or merge it into apex.
- PENDING** — Delete unused Hermes MCP sync, or call it at startup — not both half-wired.

2. Working tree

Branch `main` tracks `origin/main`. HEAD is `d1726fd` (Bus scheduling). Uncommitted local work includes `boot diagnostic`, `Hermes delivery`, `bus/reef tools`, `README`, and `pyproject.toml`.

State	Path
Modified	README.md, profiles/default/profile.md, pyproject.toml, uv.lock
Modified	huggingface_realtime.py, hermes_client.py, bus_monitor.py, ask_hermes.py, apex.py, reef_status.py
Modified	Matching tests for the files above
Untracked	src/.../startup_diagnostic.py, tests/test_startup_diagnostic.py
Untracked	_backups/2026-08-31-0807-boot-diagnostic/ and ...-full/ (not gitignored)

3. Runtime architecture

User / LAN → Web UI :7860 and Dashboard :8788 → Conversation app → speech-to-speech :8765 (llama.cpp :8080), Hermes :8642, Home Assistant, Apex / reef cache, Reachy daemon :8000. The unauthenticated LAN UI is the highlighted exposure.

Layer	Bind	Auth	Role
Conversation UI	0.0.0.0:7860	None	Speak, personalities, tools, persist .env
Control dashboard	127.0.0.1:8788	None	Start/stop local AI stack
Speech-to-speech	127.0.0.1:8765	Optional HF_TOKEN	One realtime websocket slot
llama.cpp	127.0.0.1:8080	None	Local LLM for S2S
Hermes gateway	127.0.0.1:8642	HERMES_API_KEY	Delegated household agent, 180s
Reachy daemon	:8000	SDK / local	Robot media, motion, apps

4. Findings

High (2)

● **Conversation UI binds all interfaces with no authentication - Security**

Why. Standalone `--ui` starts `uvicorn` on `0.0.0.0:7860`. JSON-RPC can make the robot speak, edit personalities, install tool spaces, and persist HF settings into the instance `.env`. `README` still describes `http://127.0.0.1:7860/`.

Fix. Default the bind to `127.0.0.1`, document LAN exposure, and add a token or bind-host setting before publishing 7860.

`src/.../main.py:277`

● Household questions still pay a nested-LLM tax · Architecture

Why. Speech-to-speech already finished the user turn, then ask_hermes POSTs to Hermes /v1/chat/completions. Hermes loads a large system prompt and tool loop. Timeout is 180s; measured waits were 45–90s. Fast paths exist for HA, bus, Apex, and reef trends, but anything else still goes through Hermes.

Fix. Keep Hermes for open-ended device control. Route more live reads through local tools or caches, the way home_assistant, monitor_bus, and apex already do.

src/.../hermes_client.py:21-23, tools/ask_hermes.py

Medium (12)

● Control dashboard has no authentication · Security

Why. Default bind is 127.0.0.1:8788, which is the right trust model for a local stack. Any local client can still start/stop llama, speech-to-speech, Hermes, and the conversation app. Changing host in services.local.json to 0.0.0.0 makes that LAN-wide.

Fix. Keep the localhost default. Refuse 0.0.0.0 unless a token is set. Do not port-forward 8788.

control_dashboard/server.py:127-215

● Dashboard log tail does not whitelist service ids · Security

Why. _tail_log builds LOG_DIR / f'{service_id}.log' from the URL path with no known-id check and no resolve-under-LOG_DIR guard. Static files are constrained; logs are not. Start/stop routes do whitelist ids.

Fix. Reject unknown ids via config.service(), then resolve the path and require it stay under LOG_DIR.

control_dashboard/server.py:76-80, 178-180

● Barge-in still does not cancel the Hermes HTTP POST · Voice loop

Why. A second ask_hermes now returns already_running instead of queueing. Completed results can be buffered and spoken after the newer turn. The in-flight httpx POST and the global asyncio lock still run for up to 180s.

Fix. Cancel the httpx request when the originating turn generation changes, and release the lock on CanceledError.

src/.../hermes_client.py:292-331

● Long-tool filler still depends on the realtime model speaking · Voice loop

Why. _acknowledge_long_running_tool injects a user prompt asking the model to say it is on it. That is better than silence, but it is not a guaranteed local filler. If the model emits a tool call with no audio, the user can still wait through Hermes.

Fix. Play a local sound or short TTS clip when ask_hermes starts, independent of the realtime backend.

src/.../huggingface_realtime.py:635-662

● Profile apply/read does not use the save-name allowlist · Security

Why. `save_user_personality` rejects names outside `[A-Za-z0-9_-]`. `delete_personality` resolves and checks the path stays under the user root. `apply()` and `read_profile()` pass `canonical_profile_name()` into `resolve_profile_dir()`, which concatenates the raw string onto `PROFILES_DIRECTORY`.

Fix. Reuse the save-name regex (and a resolve-under-root check) on read, apply, and list paths.

`src/.../config.py:421-426`, `personality_routes.py:245-249`

● HA_URL and APEX_STATUS_URL are fetched with no host policy · Security

Why. MCP HTTP URLs must be HTTPS unless the host is loopback or private LAN. Hermes and Apex/HA clients post or GET whatever the env contains. This is env-operator SSRF, not LLM-controlled, but a poisoned `.env` or UI persist can point those tokens at the wrong host.

Fix. Reuse `validate_http_mcp_url` (or the same LAN/HTTPS rule) for HA, Apex, and Hermes gateway URLs.

`tools/home_assistant.py`, `tools/reef_status.py`, `hermes_client.py`

● External tools are arbitrary Python execution · Security

Why. `core_tools` loads `REACHY_MINI_EXTERNAL_TOOLS_DIRECTORY` via `spec_from_file_location` and `exec_module`. That is the intended extension point. `AUTOLOAD_EXTERNAL_TOOLS=1` plus an unauthenticated UI widens the blast radius.

Fix. Keep it as a local trust boundary. Do not enable autoload on a LAN-exposed UI. Document that custom tools run in-process.

`src/.../tools/core_tools.py:163-190`

● Hermes MCP catalog import is unused at runtime · Architecture

Why. `sync_hermes_mcp_catalog` is only called from tests. Startup never imports `~/hermes/config.yaml`. When `ask_hermes` is on the profile, Hermes-owned MCP servers are skipped. Two integration styles are maintained; only the chat-completions bridge is live.

Fix. Delete the unused import path, or call `sync` at startup and expose those tools. Do not keep both half-wired.

`src/.../local_mcp.py:306`, `tests/test_local_mcp.py`

● Default profile ships both apex and reef_status · Architecture

Why. `apex` reuses `_load_reef_snapshot` from `reef_status`. Both are in `profiles/default/profile.md` `default_tools`. The model has two tools for one tank. Cache path is still hardcoded to `~/reef-monitor/reef_cache.json`.

Fix. Keep one reef tool on the default profile. Make the cache path configurable if it stays.

`profiles/default/profile.md`, `tools/apex.py`, `tools/reef_status.py`

● huggingface_realtime.py is a 2,002-line conversation loop · Quality

Why. Fast-path HA/bus/Apex, Hermes buffering, boot greeting, session-slot handling, and tool batching all live in one handler. Tests are strong (57) but regressions are expensive. `bus_monitor.py` is 1,369 lines with the same smell.

Fix. Extract Hermes delivery, fast-path matchers, and boot greeting. Keep the websocket loop as the orchestrator.

`src/.../huggingface_realtime.py`, `bus_monitor.py`

● Boot greeting hardcodes Walter and Sydney · **Operability**

Why. `USER_DISPLAY_NAME` and `SYDNEY_TIMEZONE` are constants in the new `startup_diagnostic` module. Fine for this machine, not for the packaged app or a second user.

Fix. Read display name and timezone from env or `startup_settings.json`.

`src/.../startup_diagnostic.py:27-28`

● Household fork is sitting uncommitted on main · **Hygiene**

Why. Branch is `main` tracking `origin/main`, with modified conversation, Hermes, bus, reef tools, README, pyproject, plus untracked `startup_diagnostic` and two full-tree `_backups` copies. Accidental `git add .` would dump backups and local-only code onto the upstream branch.

Fix. Gitignore `_backups/`. Move remaining local work onto `feat/` branches. Do not commit secrets or the backup trees.

`git status on main`

Low (7)

● Four except Exception: pass sites remain · **Quality**

Why. `AGENTS.md` forbids swallowed errors. `huggingface_realtime.py:1463` swallows connected-event set failures. `console.py` swallows `os.environ` assignment, `dotenv` reload, and optional instance `.env` load.

Fix. Log at debug/warning with the exception. Keep going, but do not pass silently.

`huggingface_realtime.py:1463`, `console.py:350`, `377`, `789`

● mypy does not type-check control_dashboard · **Quality**

Why. `pyproject.toml` sets `files = ["src/"]`. The dashboard is 2,381 lines of process control and is linted by `ruff` when you run `ruff check .`, but strict `mypy` never sees it.

Fix. Add `control_dashboard/` to `[tool.mypy] files`, or a second `mypy` invocation in the local gate.

`pyproject.toml [tool.mypy]`

● Python version floor disagrees with itself · **Docs**

Why. `pyproject.toml` requires `>=3.11`. `AGENTS.md` still says the package targets `>=3.10`. README install examples use 3.12. `mypy` runs as 3.12.

Fix. Say `>=3.11` everywhere, keep examples on 3.12.

`AGENTS.md`, `pyproject.toml`, `README.md`

● Code default is deployed cloud if .env is missing · **Operability**

Why. This checkout is intended for local speech-to-speech. `config.py` still defaults `HF_REALTIME_CONNECTION_MODE` to `deployed`. `.env.example` sets `local`. A fresh clone without copying `.env` sends audio to Hugging Face cloud.

Fix. Either default this fork to `local`, or fail closed until the mode is explicit.

`src/.../config.py`, `.env.example`

● **Dashboard HTTP and several tools have no direct tests · Tests**

Why. About 450 tests cover the realtime loop, bus monitor, Hermes client, boot diagnostic, and dashboard redaction. `control_dashboard/server.py` has no HTTP integration tests. `task_status`, `task_cancel`, `dance`, `move_head`, `remember`, and `forget` have no dedicated tool tests.

Fix. Add a dashboard log-path and unknown-id HTTP test. Cover `task_cancel` behavior. Leave thin motion tools untested unless they break.

`tests/`, `control_dashboard/server.py`

● **Subsystem health is probed in two places · Quality**

Why. `startup_diagnostic.py` and `control_dashboard/checks.py` both hit Hermes, HA, Apex, speech-to-speech, and Reachy. The new boot greeting needed robot-side probes; the dashboard needed process orchestration. The URLs and timeouts can drift.

Fix. Share URL builders and timeout constants. Keep the two callers; they serve different processes.

`startup_diagnostic.py`, `control_dashboard/checks.py`

● **Hermes session id lasts for the whole process · Architecture**

Why. `get_hermes_session_id()` is a process UUID. Profile switches, forget, and sleep do not rotate it, so Hermes can keep a long tool-loop history against a short voice system prompt.

Fix. Rotate on profile change, forget, and `go_to_sleep`.

`src/.../hermes_client.py`

5. What is solid

Security controls that exist

No `eval`, `exec`, `pickle`, `yaml.load`, or `shell=True` in app code. Dashboard process start uses `argv` lists from `services.json`, not HTTP bodies. Stop is gated by `process_match` or an owned PID. Static file serving is path-constrained. Personality save/delete reject `../`. MCP HTTP requires HTTPS off-LAN. Dashboard env APIs mask tokens.

Recent local hardening that landed

Boot diagnostic speaks stack health once per process. Hermes no longer queues a second 180s POST. Reef cache reads are logged instead of swallowed. Fast paths cover lights, bus, Apex, and reef trends so the nested LLM is not on every household question.

6. Prior Hermes audit — still open?

Status	Item	Now
Open	Nested LLM for household questions	Still the dominant latency. Fast paths cover HA, bus, Apex, and reef trends only.
Partial	Barge-in vs in-flight Hermes POST	<code>already_running</code> guard and delayed speech buffer landed. HTTP cancel did not.

Status	Item	Now
Partial	Spoken filler during long Hermes waits	_acknowledge_long_running_tool prompts the model. No local audio clip.
Open	Hermes MCP catalog unused at runtime	sync_hermes_mcp_catalog remains test-only.
Fixed	reef_status swallowed cache read errors	Now logs OSError/JSONDecodeError and returns a spoken error string.
Fixed	No startup signal that Hermes/HA/Apex are reachable	startup_diagnostic.py probes the stack once per process and speaks the result. 24 tests.
Partial	Global Hermes lock queued a second 180s wait	A second call now returns already_running. Distinct queries still cannot overlap because the lock remains.

Compared against the earlier Hermes/Reachy audit canvas in this workspace.

7. Code size hotspots

Largest Python modules (physical lines of code). Source: this checkout · 31 August 2026.

Module	Lines
huggingface_realtime.py	2,002
bus_monitor.py	1,369
console.py	967
tool_spaces.py	789
startup_diagnostic.py	758
home_assistant.py	675

8. Recommended next work (checklist)

Same six items as section 1, formatted as a checklist for tracking.

#	Status	Work
1	Pending	Bind the conversation UI to 127.0.0.1 by default; document 0.0.0.0 as an explicit LAN choice.
2	Pending	Whitelist dashboard log service ids and resolve-under-LOG_DIR.
3	Pending	Cancel the Hermes httpx POST when the originating turn is superseded.
4	Pending	Add _backups/ to .gitignore and move local work off main onto feat/ branches.
5	Pending	Drop reef_status from the default profile or merge it into apex.
6	Pending	Delete unused Hermes MCP sync, or call it at startup — not both half-wired.

Audit method: read-only exploration of `src/`, `control_dashboard/`, `tests/`, `profiles/`, `pyproject.toml`, and `README.md`, plus verification of the highest-risk lines. Generated 31 August 2026 from the full project audit canvas. This PDF is an export; it was not committed to the repository.